

CYBER SECURITY TASK 2 — 2026

Future Interns · Security Awareness Series

Phishing Detection & Awareness Report

A professional analysis of phishing email samples, threat indicators, risk classifications, and employee prevention guidelines.

Prepared By	Lizo Ndawana
Date	April 2026
Classification	Internal / Training Use

01 Executive Overview

Phishing remains the single most prevalent entry point for corporate cyber attacks in 2026. Over 90% of successful data breaches begin with a phishing email. These attacks succeed not because of technological failures, but because they exploit human psychology urgency, fear, and trust.

This report was produced as part of the Future Interns Cyber Security Task 2 program. It analyses three representative phishing email samples, identifies their techniques, classifies each by risk level, and translates findings into clear, actionable guidance for all employees.

The goal is security education, not offensive activity. All email samples are drawn from public educational repositories and fabricated examples representative of real-world attacks.

⚠ Scope Note: This report covers email-based phishing only. Smishing (SMS), vishing (voice), and spear-phishing campaigns are addressed in separate reports in this series.

02 Risk Classification Framework

Each analysed email is assigned one of three risk classifications, determined by the number and severity of phishing indicators present:

✓ SAFE	No indicators detected. Email appears legitimate. No action required beyond routine caution.
⚠ SUSPICIOUS	1–2 minor indicators present. Treat with caution. Do not click links or share data without verification.
✗ PHISHING	3+ indicators confirmed. High confidence phishing attempt. Delete immediately and report to IT Security.

03 Email Sample Analyses

Sample 1 — Account Verification Phish

⚠ Urgent: Your Account Will Be Locked
Source: Fabricated example representative of real campaigns

✗ PHISHING

From: security-team@secure-account-verify[.]com
To: user@company.com
Subject: ⚠ Urgent: Your Account Will Be Locked

Dear User,

We noticed suspicious activity on your account.
To avoid account suspension, please verify your details immediately.

🔗 Verify Now: [http://secure-account-verify\[.\]com/login?session=9f2k...](http://secure-account-verify[.]com/login?session=9f2k...)

Failure to verify within 24 hours will result in permanent account lock.

Regards,
Security Team

	Indicator	Value	Finding
✉️	Sender Domain	secure-account-verify[.]com	🚩 Not affiliated with any legitimate service
🔗	Link Domain	secure-account-verify[.]com	🚩 Matches suspicious sender; no HTTPS
👤	Greeting	"Dear User"	🚩 Generic — no personalisation
🕒	Urgency Tactic	24-hour deadline threat	🚩 Classic pressure technique
✉️	SPF / DKIM	Not verifiable (example)	⚠️ Would likely fail both checks
📎	Attachments	None	✅ No malicious files

Red Flags Identified:

- ▶ **Fake sender domain:** "secure-account-verify.com" is not affiliated with any real service. Legitimate companies always email from their own verified domain.
- ▶ **Fear & urgency language:** "account will be locked", "permanent account lock", "within 24 hours" designed to panic the user into acting without thinking.
- ▶ **Credential-harvesting link:** The URL leads to a fake login page. It uses HTTP (not HTTPS) and includes a session tracking parameter.
- ▶ **Generic salutation:** Real account emails address you by your registered name. "Dear User" is a hallmark of mass-sent phishing campaigns.
- ▶ **Vague sender identity:** "Security Team" with no company name, no contact number, no support link all of which legitimate organisations include.

Sample 2 — IT Department Password Reset

Action Required: Reset Your Password Now

Source: Fabricated example — IT Help-desk impersonation pattern

✖ PHISHING

From: [it-helpdesk@company-itsupport\[.\]net](mailto:it-helpdesk@company-itsupport[.]net) (display: helpdesk@yourcompany.com)
Reply-To: [collect@harvest-logins\[.\]ru](mailto:collect@harvest-logins[.]ru)
To: all-staff@yourcompany.com
Subject: Action Required: Reset Your Password Now

Dear Employee,

As part of our mandatory quarterly security upgrade, all employees must reset their passwords by end of business today.

👉 [http://yourcompany-it-portal\[.\]net/reset?uid=emp_2948](http://yourcompany-it-portal[.]net/reset?uid=emp_2948)

Accounts not updated will be suspended immediately.

IT Help Desk
yourcompany.com

	Indicator	Value	Finding
✉	Display Name Spoof	Shows @yourcompany.com	❗ Actual sender is different domain
↩	Reply-To Mismatch	harvest-logins[.]ru	❗ Replies go to attacker (.ru)
🔗	Reset Link	yourcompany-it-portal[.]net	❗ Typosquat — not official domain
🎯	Targeting	Sent to all-staff list	❗ Mass internal impersonation
ID	URL Tracking	?uid=emp_2948	❗ Used to correlate victims
📎	Attachments	None	✓ No malicious files

Red Flags Identified:

- ▶ **Display name spoofing:** The email appears to come from a trusted internal address but the actual sending domain is entirely different. Always expand sender details.
- ▶ **Reply-To harvesting:** Replies are silently redirected to a Russian-registered domain controlled by the attacker — a technique to collect credentials without detection.
- ▶ **Typosquatting domain:** "yourcompany-it-portal.net" looks plausible at a glance but differs from the real company domain. Real IT portals use the company's actual domain with HTTPS.
- ▶ **Same-day deadline:** "End of business today" creates panic. Legitimate IT password resets give advance notice and use verified internal channels.
- ▶ **UID tracking parameter:** The ?uid= value lets attackers track which employees clicked, enabling targeted follow-up attacks.

Sample 3 — Invoice / Finance Phish (BEC)

INV-20260415: Payment Due — Please Review Attached

Source: Fabricated example — Business Email Compromise (BEC) pattern

⚠ SUSPICIOUS

From: [accounts@acme-supplies\[.\]co](mailto:accounts@acme-supplies[.]co) (unverified)

To: finance@yourcompany.com
Subject: INV-20260415: Payment Due — Please Review Attached

Hi,

Please find attached invoice INV-20260415 for services rendered in March 2026.
Payment of R 48,500.00 is due by 25 April 2026.

Please note our banking details have changed. Use the new details on the attached PDF.

Regards, Accounts Payable
Acme Supplies Ltd | Tel: 011 555 0192

	Indicator	Value	Finding
	Sender Domain	acme-supplies[.]co	⚠ Plausible — needs verification
	Attachment	PDF Invoice (claimed)	🚩 PDFs can embed malicious links
	Banking Change	"Details have changed"	🚩 Classic BEC redirection tactic
	Amount	R 48,500.00	⚠ High-value payment request
	Links in Body	None visible	✓ No direct URL lures
	Contact Number	011 555 0192	⚠ Verify via official records only

Red Flags Identified:

- ▶ **Banking detail change request:** The defining hallmark of Business Email Compromise. Attackers redirect payments to their own account. Any banking change must be verified by phone using a number sourced independently never from the email itself.
- ▶ **PDF attachment risk:** Even a legitimate-looking invoice PDF can contain embedded links to credential-harvesting pages. Open only after verifying the sender.
- ▶ **Plausible but unverified domain:** "acme supplies.co" looks real. Cross-reference against previously used email addresses, phone, and bank records before processing any payment.

04 Analysis Summary

#	Sample	Attack Type	Key Indicators	Risk
1	Account Verification	Credential harvesting	Fake domain, urgency, generic greeting, suspicious URL	✗ Phishing
2	IT Password Reset	Display name spoofing + Reply-To harvesting	Spoofed sender, Reply-To .ru, typosquatting, UID tracking	✗ Phishing

3	Invoice / Finance (BEC)	Payment redirection	Banking change claim, unverified domain, high-value request	⚠ Suspicious
---	-------------------------	---------------------	---	--------------

Two out of three samples were confirmed Phishing. The third is classified Suspicious due to insufficient domain evidence, but the banking detail change tactic alone warrants escalation and out-of-band verification before any payment is processed.

05 Prevention & Awareness Guidelines

The following guidelines should be distributed to all employees as part of onboarding and recurring security training. They are written in plain language to maximise comprehension across all technical ability levels.

☑ Do's	✗ Don'ts
- Verify sender email addresses — check the domain after the "@", not just the display name. - Hover over links before clicking to preview the real destination URL. - Call suppliers to verify banking changes using a number from your own records, not from the email. - Report suspicious emails to your IT/security team immediately. - Use multi-factor authentication (MFA) on all accounts. - Trust your instincts — if something feels rushed or unusual, pause and verify.	- Don't click links in unexpected emails, even if they look legitimate. - Don't enter passwords or OTPs on a site you reached by clicking an email link. - Don't open unexpected attachments, especially .exe, .zip, .docm, or .pdf files from unknown senders. - Don't act on "urgent" or "time-limited" demands without verifying through a separate channel. - Don't assume an email is safe because the sender name looks familiar. - Don't update banking details for any supplier based solely on an emailed request.

Quick Reference: How to Spot a Phishing Email

 Check the Sender Domain The part after "@" is the real sender. "security@paypal.com" is not PayPal.	 Spot Fake Urgency Deadlines of "today" or "24 hours" are pressure tactics. Slow down and verify.
 Preview Links Before Clicking Hover (don't click) over any link. If the URL doesn't match the expected site, do not click.	 Treat Attachments as Threats Never open unexpected attachments. Even PDFs can contain malicious embedded content.
 Generic Greetings = Red Flag "Dear Customer" or "Dear User" suggests a mass-sent phishing attempt.	 Verify Out-of-Band When unsure, call or message the sender using contact details you already have on record.

06 Tools & Analysis Methodology

Tool	Purpose	URL
Google Admin Toolbox	Email header analysis — SPF, DKIM, DMARC inspection	toolbox.googleapps.com
MXToolbox	Secondary header analyser and domain reputation	mxtoolbox.com/EmailHeaders.aspx
VirusTotal	URL and attachment scanning (70+ threat engines)	virustotal.com
WHOIS Lookup	Domain registration and age verification	whois.domaintools.com
PhishTank	URL reputation against phishing database	phishtank.org

Analysis Approach (5-Step Methodology)

- **Header Inspection** — Extract and analyse the full email header to verify SPF/DKIM/DMARC status, identify the true sending server IP, and detect Reply-To mismatches.
- **Domain Verification** — Cross-reference sending domain against WHOIS records, check domain age, and compare against known legitimate domains.
- **Link Analysis** — Hover-inspect all URLs, expand shortened links, and submit to VirusTotal and PhishTank. Never click links during analysis.
- **Content Analysis** — Identify psychological manipulation tactics (urgency, fear, authority impersonation) and assess language quality.
- **Risk Classification & Documentation** — Score indicators against the classification framework and document findings for training and future reference.

07 Organisational Recommendations

Beyond individual awareness, the following organisational measures significantly reduce phishing risk:

Recommendation	Priority	Description
Enable MFA Org-Wide	HIGH	Multi-factor authentication prevents stolen credentials from being sufficient to compromise accounts.
Deploy DMARC / DKIM / SPF	HIGH	Email authentication protocols that prevent domain spoofing and display-name impersonation.
Email Gateway Filtering (ATP)	HIGH	Deploy advanced threat protection to scan links and attachments at the gateway level before delivery.
Payment Verification Policy	HIGH	Mandate dual-authorisation and out-of-band phone verification for any banking detail changes.
Regular Phishing Simulations	MEDIUM	Send controlled phishing test emails to staff and use click-through data to target training efforts.
Incident Reporting Culture	MEDIUM	Establish a simple, no-blame reporting mechanism to encourage staff to flag suspicious emails without fear of consequence.

